Republic of the Philippines
POLYTECHNIC UNIVERSITY OF THE PHILIPPINES
SAN PEDRO CAMPUS
PUP, Main Road, Barangay United Bayanihan, City of San Pedro, Laguna

Applicant Management System Database Roles and Privileges

Activity 4 Progress Documentation

1. Introduction

This documentation presents the database administration and access-control activities performed for Group07's Applicant Management System (AMS) as part of COMP018 Activity 4.

The activity focused on reviewing the database structure, configuring PostgreSQL roles, applying appropriate privileges, and testing whether each database user could perform only the actions allowed by their assigned role.

2. Project Overview

Project Name: Applicant Management System (AMS)
Group: Group 7
Database: grp07_applicantdb
Database Management System: PostgreSQL 18.6
Backend: PHP
Schema: public

The system manages applicant records, applications, interviews, requirements, departments, positions, application statuses, and user accounts.

The application defines three user roles:

- Administrator – manages system records and performs administrative operations.
- Staff – handles applicant and application-related operations.
- Viewer – has read-only access to approved records.

3. Database Inspection

The existing database was inspected before assigning privileges.

The database contains 9 tables and 8 sequences.

Tables and recorded row counts:

Table	Number of Records
department	5
position	8
applicant	10
application_status	5
application	12
interview	8
requirement	6
applicant_requirement	20
users	3
Total	77

All inspected tables are owned by postgres and belong to the public schema.

The inspection included the database, schema, tables, sequences, existing roles, and seeded records.

4. Role Creation and Configuration

The following PostgreSQL roles were used for Group07:

4.1 Group Roles (NOLOGIN)

Group Role	Purpose
grp07_app_admin_grp	Administrative database access
grp07_app_runtime_grp	Application runtime access for Staff and the PHP backend
grp07_app_readonly_grp	Read-only access for Viewer

4.2 Login Roles

Login Role	Assigned Group Role
grp07_ams_admin	grp07_app_admin_grp
grp07_ams_app_user	grp07_app_runtime_grp
grp07_ams_viewer	grp07_app_readonly_grp

The login roles were successfully verified as members of their corresponding group roles.

5. Privilege Assignment

Privileges were assigned according to the application's intended access requirements and the principle of least privilege.

Administrator group

- SELECT, INSERT, UPDATE, and DELETE on all 9 tables.
- Full privileges on all 8 sequences.
- CONNECT on the database.
- USAGE on the public schema.
- No schema CREATE privilege or PostgreSQL superuser privileges.

Runtime group

- SELECT, INSERT, UPDATE, and DELETE on the 7 operational tables:
  - applicant
  - applicant_requirement
  - application
  - department
  - interview
  - position
  - requirement
- SELECT only on application_status.
- SELECT on users.
- UPDATE only on the password_hash column of users.
- USAGE and SELECT on all 8 sequences.
- CONNECT on the database and USAGE on the public schema.

The limited password-hash update permission supports the application's password verification and password rehashing process without allowing runtime users to modify other user-account fields.

Read-only group

- SELECT on the 8 approved tables, excluding users.
- No INSERT, UPDATE, or DELETE privileges.
- No sequence privileges.
- CONNECT on the database and USAGE on the public schema.
- account_name
- email
- avatar_url
- account_status

6. Access Control Testing

Each login role was tested through a separate PostgreSQL connection.

Administrator (grp07_ams_admin)

- Successfully accessed applicant records.
- Successfully accessed user records.
- Successfully performed INSERT, UPDATE, and DELETE operations within a transaction.

- The transaction was rolled back to preserve the original data.

Runtime (grp07_ams_app_user)

- Successfully retrieved applicant and application records.
- Successfully performed INSERT, UPDATE, and DELETE operations on applicant within transactions.
- Successfully accessed users for authentication-related operations.
- Successfully updated the password_hash column within a transaction.
- Received permission-denied errors when attempting to modify application_status.
- Received a permission-denied error when attempting to update the role column in users.

Viewer (grp07_ams_viewer)

- Successfully retrieved applicant records.
- Received permission-denied errors when attempting INSERT, UPDATE, and DELETE operations.
- Received a permission-denied error when attempting to access users.

All successful modification tests were rolled back to avoid changing the original database records.

7. Issues and Limitations

During the configuration and testing process, the following issues and limitations were identified:

- The initial runtime INSERT test failed because required applicant fields, including email and phone, were not supplied. This was a data-validation issue rather than a privilege issue.
- Sequence privileges initially needed to be assigned to the administrator and runtime groups.
- The application runtime requires access to user records for authentication, but its update permission must remain limited to the password hash column.
- The Viewer role must not access the users table because it contains sensitive authentication information.
- Database access control does not replace application-level authorization. The application must also enforce its own role restrictions.

8. Evidence and Repository

The SQL script and supporting evidence are organized under the Group07 folder in the Activity 4 repository.

Repository links:

- **Repository:** https://github.com/123airabels/Car_Rental_Management_System
- **UniSync access-control folder:** https://github.com/123airabels/Car_Rental_Management_System/tree/main/db-access-control/Group07
- **SQL script:** https://github.com/123airabels/Car_Rental_Management_System/blob/main/db-access-control/Group07/grp07_roles_and_privileges.sql
- **Evidence folder:** https://github.com/123airabels/Car_Rental_Management_System/tree/main/db-access-control/Group07/evidence

8.1 Evidence Screenshots

A total of 24 evidence screenshots were organized and uploaded to the Group07 evidence folder. The screenshots cover:

- Role configuration and memberships
- Database and schema privileges
- Table and sequence privileges
- Default privileges
- Administrator allowed operations
- Runtime allowed and denied operations
- Viewer denied operations
- Runtime password-hash update permission

The screenshots provide supporting proof of the assigned privileges and the results of the access-control tests

9. SQL Scripts Summary

The script documents the following configurations:

1. Database CONNECT privileges.
2. Schema USAGE privileges.
3. Login role memberships.
4. Administrator table privileges.

5. Runtime table and column-level privileges.
6. Viewer read-only privileges.
7. Sequence privileges.
8. Default privileges for future tables and sequences.

The script does not contain database passwords or other login credentials.

10. Verification Results

The following configurations were verified:.

Verification Item	Result
Login role memberships	Passed
Database CONNECT privileges	Passed
Public schema USAGE privileges	Passed
Administrator table privileges	Passed
Runtime table privileges	Passed
Runtime password_hash column update	Passed
Viewer read-only restrictions	Passed
Sequence privileges	Passed
Default privileges	Passed
Allowed and denied access tests	Passed

The tests confirmed that the configured database roles follow the intended access-control design.

11. Issues and Fixes

Issue	Action Taken
Initial runtime INSERT lacked required fields	Added the required email and phone values and repeated the test using a transaction.
Sequence privileges were initially missing	Granted ALL privileges to the administrator group and USAGE, SELECT to the runtime group.
Runtime access to user records needed restrictions	Retained SELECT access and limited UPDATE to password_hash.
Runtime modification of application statuses was not allowed	Verified that INSERT, UPDATE, and DELETE were denied.
Viewer modification and sensitive-table access were not allowed	Verified that write operations and access to users were denied.

12. Feedback to the Owning Group

Based on the database inspection and access-control testing, the following recommendations are suggested for the Group07 Applicant Management System:

- Maintain role-based access control. Continue separating Administrator, Staff, and Viewer permissions to ensure that users can only perform actions related to their responsibilities.
- Protect sensitive user information. Keep the users table restricted to authorized accounts and maintain limited access to password-related fields.
- Validate required fields. Ensure that required applicant information, such as email and phone number, is properly validated before database insertion to prevent incomplete records.
- Maintain database security. Avoid using database superuser accounts for regular application operations. Continue using dedicated database accounts with limited privileges.
- Review permissions regularly. Check role memberships and assigned privileges whenever application features or user responsibilities change.

Overall, the database structure and access-control configuration were consistent with the documented application requirements. These recommendations are intended to help maintain database security, data integrity, and proper access management.

13. AI Usage Declaration

AI assistance was used to support the database administration activity, including reviewing role requirements, planning privilege assignments, preparing SQL statements, explaining PostgreSQL permission errors, and organizing the progress documentation.

The database commands and access-control tests were executed and verified in PostgreSQL. AI assistance was used as a support tool and did not replace the actual database implementation and testing.

14. Conclusion

The Group07 Applicant Management System database was successfully configured and tested for Activity 4.

The Administrator, Runtime, and Viewer roles were assigned privileges according to their intended responsibilities. Allowed and denied operations were tested using their respective login accounts.

The results demonstrate the use of role-based access control and the principle of least privilege in managing access to the Applicant Management System database.

The SQL script and 24 supporting evidence screenshots are organized in the Group07 repository folder as documentation of the completed database administration and access-control activities.